

Aula 3 (Módulo 04) — Análise de PCAP

Esta é a aula de consolidação do Módulo 04: juntar tudo (Módulo 03 + Wireshark) em um **roteiro prático** de análise de uma captura de tráfego (arquivo `.pcap` / `.pcapng`).

1. O que é um arquivo PCAP

PCAP (*Packet Capture*) é um arquivo que guarda uma captura completa de tráfego de rede — cada pacote, byte a byte, como passou pela interface de rede no momento da captura. É o "vídeo" completo da comunicação, em oposição a um log resumido (como os do Zeek, aula anterior).

2. As perguntas centrais de toda análise de PCAP

Independente do caso, este roteiro de perguntas se aplica sempre — memorize-o, ele volta em Threat Hunting (Módulo 14) e Incident Response (Módulo 15):

1. **Quem iniciou a comunicação?** (cliente vs. servidor — Módulo 00, Aula 3)
2. **Qual foi o primeiro pacote?** (geralmente um SYN, se for TCP — Módulo 03, Aula 3)
3. **Qual protocolo foi usado?** (TCP/UDP, e em cima disso: HTTP, DNS, TLS...)
4. **Quais IPs e portas estão envolvidos?** (são conhecidos/esperados, ou domínio/IP nunca visto antes?)
5. **Houve resolução DNS associada?** (qual domínio foi consultado antes da conexão? Módulo 03, Aula 4)
6. **Houve transferência de dados relevante?** (volume incomum? Lembra do NetFlow/exfiltração, aula anterior)
7. **Há sinais de comportamento malicioso?** (certificado TLS estranho, command line ofuscada em um payload HTTP, handshake incompleto em massa — SYN flood, Módulo 03 Aula 3)

3. Roteiro prático no Wireshark

1. Abrir o .pcap
2. Statistics → Protocol Hierarchy
 - visão geral de quais protocolos aparecem e em que proporção (muito DNS? Muito HTTP puro, sem HTTPS, num ambiente que deveria ser todo criptografado? já é um dado)
3. Statistics → Conversations
 - lista de "quem falou com quem", quantos bytes, por quanto tempo (equivalente, dentro do Wireshark, ao que o NetFlow mostra de forma mais leve)
4. Filtrar por handshakes incompletos:
tcp.flags.syn==1 and tcp.flags.ack==0
 - muitos SYN sem resposta completa, de/para o mesmo IP, é sinal de scanning ou SYN flood
5. Filtrar por DNS:
dns
 - quais domínios foram consultados? Algum parece gerado aleatoriamente (padrão DGA, Módulo 03 Aula 4) ou parecido com uma marca conhecida (typosquatting)?
6. Filtrar por HTTP em texto claro (sem TLS):
http.request
 - o que foi pedido? Algum User-Agent, path ou parâmetro suspeito?
7. Clique com o botão direito em uma conexão → Follow → TCP Stream
 - reconstrói a conversa inteira daquela conexão específica, como texto legível (só funciona se não estiver criptografado por TLS)

4. Onde praticar com PCAPs reais e seguros

Nunca capture tráfego de uma rede sem autorização explícita (isso é ilegal e, mesmo em laboratório próprio, deve ser feito de forma consciente). Para praticar com segurança, existem repositórios públicos mantidos para fins **educacionais**, com capturas de tráfego malicioso real (já neutralizado/isolado, para estudo):

- **Wireshark — Sample Captures** (capturas variadas, oficiais do próprio projeto Wireshark, focadas em protocolos): <https://wiki.wireshark.org/SampleCaptures>
- **Malware-Traffic-Analysis.net** (referência muito usada na comunidade de Blue Team — capturas reais de tráfego malicioso, com exercícios guiados e respostas, mantidas por um analista de segurança independente e bem conhecido na comunidade): <https://www.malware-traffic-analysis.net/>

Nota sobre fonte: o Malware-Traffic-Analysis.net é uma fonte **comunitária** (não é documentação oficial de um fabricante), mas é amplamente reconhecida e citada em treinamentos formais de Blue Team justamente por oferecer

capturas reais com contexto educacional — por isso a menciono aqui, deixando claro que é comunidade, não oficial (seguindo a hierarquia de fontes do `CLAUDE.md` deste repo).

Quando você baixar um PCAP de laboratório para praticar, documente o exercício aqui no repositório: salve o arquivo em `../pcaps/`, e escreva suas conclusões como um mini-relatório em `../reports/` — isso já começa a construir o seu portfólio de investigação real.

5. Exercício sugerido (para quando tiver um PCAP em mãos)

1. Baixe uma captura simples de exemplo do Wireshark Sample Captures.
2. Abra no Wireshark e aplique o roteiro da seção 3, respondendo as 7 perguntas da seção 2 por escrito.
3. Salve suas respostas em `reports/pcap-analysis-01.md` (crie o arquivo), citando o nome do PCAP usado.

Não vou revelar as respostas de um PCAP específico aqui de propósito — o objetivo do Threat Hunting/IR (módulos mais à frente) é justamente treinar você a responder essas perguntas sozinho, sistematicamente.

6. Recapitulando o Módulo 04

- IDS detecta/alerta, IPS bloqueia; NIDS/HIDS observam rede vs. host; detecção por assinatura (conhecido) vs. anomalia (desconhecido).
- Wireshark = inspeção pacote a pacote; Zeek = logs estruturados por conexão; Suricata = alertas/bloqueio em tempo real via regras; NetFlow = metadados leves de volume, ótimo para exfiltração.
- Análise de PCAP segue sempre o mesmo roteiro de perguntas: quem iniciou, qual protocolo, quais IPs/portas, houve DNS, houve volume de dados relevante, há sinal de comportamento malicioso.

Módulo 04 concluído. 🎉

Próximo módulo

Módulo 05 — Wi-Fi / Wireless Security: 802.11, SSID/BSSID, WPA/WPA2/ WPA3, e o uso do seu adaptador AR9271 — sempre em laboratório/rede própria, seguindo as regras do `CLAUDE.md` deste repositório.

Fontes recomendadas

- **Wireshark — "Follow TCP Stream" e "Statistics" (documentação oficial):** referência das funcionalidades usadas neste roteiro. https://www.wireshark.org/docs/wsug_html_chunked/ChStatistics.html
- **Wireshark Wiki — "SampleCaptures":** repositório oficial de PCAPs de exemplo do próprio projeto. <https://wiki.wireshark.org/SampleCaptures>